STRIDE ISP 2.2 – GV.RM

Risk Management Standards

Version [2.0]

Purpose:

This document defines the Stride standards related to Risk Management.

Scope and Applicability

These policies and standards apply to all Stride-owned technology and business operations.

All workforce members and their respective facilities supporting Stride business operations, technology, or both, wherever Stride data is stored or processed, including any third party contracted by Stride to handle, process, transmit, store, or dispose of Stride data are subject to the requirements of this document.

All data, systems, activities, and assets owned, leased, controlled, or used by Stride, its agents, contractors, or other business partners on behalf of Stride are within the scope of the requirements of this document.

The requirements outlined in this document apply where technically feasible and commercially reasonable, as determined by executive management. Any exceptions to these standards must be requested using the approved workflow and remain documented until compliance has been achieved. Exceptions are only granted temporarily for periods of up to one calendar year.

Definitions

All definitions are located within Stride - ISP 1.2 – IT Policy Definitions.

Any inquiries regarding terminology or clarity may be directed to Stride's Information Security Team for assistance.

Publication Owners

Johnny Burns – Point of Contact, Content Coordinator & Author

Jen Havenner – Business Owner

Mark Williams – Executive Sponsor

Document Control

This document may contain proprietary, confidential, or sensitive information owned wholly by Stride Inc. Any distribution of the information contained within this document, in whole or in part, outside of Stride or its subsidiary entities requires the approval of the Executive Sponsor.

This document will be reviewed at least annually and re-issued when revisions are necessary. Any changes introduced in the most recent version are itemized below. Obsolete copies should be destroyed or archived upon the release of the newest version.

Implementation and Compliance

All business units are required to comply with any changes applied to the most recent version of this publication within 90 days from the date of publication.

Change History

Version	Date of Change	Summary of Change(s)
1.0	6/15/2022	Initial Release and Publication
1.1	12/01/2022	- Added Change History - Updated and/or redacted language for clarity where necessary
1.2	03/17/2023	- Updated approvals section
1.3	01/01/2024	- Updated Purpose/Scope/Document Control/Implementation and Compliance - Changed formatting to new standard - Changed document images
2.0	01/31/2025	- Major change to align with NIST 2.0 - Previous document titled and filed under ID.RM shifted to GV.RM and rebuilt to accommodate alignment with NIST 2.0
2.0	02/24/2025	- Approved Mark Williams - CISO
2.0	02/27/2025	- Published

RISK MANAGEMENT STRATEGY

The organization's priorities, constraints, risk tolerance and appetite statements, and assumptions are established, communicated, and used to support operational risk decisions.

GV.RM-01: RISK MANAGEMENT OBJECTIVES AGREEMENT

Risk management objectives are established and agreed to by organizational stakeholders.

Standards:

- Stride's technology and cybersecurity risk management strategies and frameworks are approved by the governing authority (e.g., the Board of Directors or one of its committees).
- These strategies and frameworks are incorporated into the overall business strategy and enterprise risk management framework.
- Stride's technology and cybersecurity risk management strategies and frameworks are informed by applicable international, national, and financial services industry standards and guidelines.
- The Organization ensures that its risk management approach aligns with these standards to maintain compliance and best practices.
- Stride has established, and maintains, technology and cybersecurity programs designed to protect the confidentiality, integrity, and availability of its information and operational systems, commensurate with the organization's risk appetite and business needs.

References:

- CRI Profile v2.0: GV.RM-01
- CRI Profile v2.0: GV.RM-01.01
- CRI Profile v2.0: GV.RM-01.02
- CRI Profile v2.0: GV.RM-01.03
- CRI Profile v2.0: GV.RM-01.04

- CRI Profile v2.0: GV.RM-01.05
- SP 800-221A: GV.RR-2
- CSF v1.1: ID.RM-1

GV.RM-02: RISK APPETITE AND RISK TOLERANCE STATEMENTS

Risk appetite and risk tolerance statements are established, communicated, and maintained.

Standards:

- The governing authority (e.g., the Board of Directors or one of its committees) endorses and regularly reviews Stride's technology and cybersecurity risk appetite.
- The governing authority is regularly informed about the status of, and material changes to, the organization's inherent risk profile.
- Determination of the Stride's risk appetite and tolerance includes consideration of the organization's stakeholder obligations, role in critical infrastructure, and sector-specific risk analysis.

References:

- CRI Profile v2.0: GV.RM-03
- CRI Profile v2.0: GV.RM-03.01
- CRI Profile v2.0: GV.RM-03.02
- CRI Profile v2.0: GV.RM-03.03
- CRI Profile v2.0: GV.RM-03.04
- SP 800-221A: GV.PO-2
- SP 800-221A: GV.PO-3
- CSF v1.1: ID.GV-4

GV.RM-03: Enterprise Risk Integration

Technology and cybersecurity risk management activities and outcomes are included in enterprise risk management processes.

Standards:

- Stride's technology and cybersecurity risk management frameworks and programs are integrated into the enterprise risk management framework.
- The organization's business continuity and resilience strategy and program align with and support the overall enterprise risk management framework.
- Stride's technology and cybersecurity risk management and risk assessment processes are consistent with the organization's enterprise risk management policies, procedures, and methodologies.
- These processes include criteria for the evaluation and categorization of enterprise-specific risks and threats.
- Stride's technology and cybersecurity risk management considerations are integrated into daily operations, cultural norms, management discussions, and management decision-making, tailored to address enterprise-specific risks (both internal and external).

References:

- CRI Profile v2.0: GV.RM-03
- CRI Profile v2.0: GV.RM-03.01
- CRI Profile v2.0: GV.RM-03.02
- CRI Profile v2.0: GV.RM-03.03
- CRI Profile v2.0: GV.RM-03.04
- SP 800-221A: GV.PO-2
- SP 800-221A: GV.PO-3
- CSF v1.1: ID.GV-4

GV.RM-04: Risk Response Strategic Direction

Strategic direction that describes appropriate risk response options is established and communicated.

Standards:

- The governing authority (e.g., the Board of Directors or one of its committees) and senior management provide guidance, direction, and credible challenges in the design and implementation of risk management strategies.
- They assess identified risks against risk appetite and risk tolerance.
- They select appropriate risk treatment approaches.

References:

- CRI Profile v2.0: GV.RM-04
- CRI Profile v2.0: GV.RM-04.01
- SP 800-221A: GV.BE-1
- CSF v1.1: ID.RM-2

GV.RM-05: Risk Management Lines of Communication

Lines of communication across the organization are established for technology and cybersecurity risks, including risks from suppliers and other third parties.

Standards:

- Stride has a process for monitoring its technology, cybersecurity, and third-party risks.
- Risks that exceed risk appetite are escalated to management.
- Risks with potential impact on multiple operating units are identified.
- The organization establishes minimum requirements for its third parties, including how they will communicate and coordinate in times of emergency, addressing:
    - Joint maintenance of contingency plans.

- Responsibilities for responding to incidents, including forensic investigations.
- Planning and testing strategies to address severe events and identify single points of failure.
- Incorporating the potential impact of an incident into their BCM (Business Continuity Management) process and ensuring resilience capabilities are in place.

References:

- CRI Profile v2.0: GV.RM-05
- CRI Profile v2.0: GV.RM-05.01
- CRI Profile v2.0: GV.RM-05.02
- SP 800-221A: GV.PO-1
- CSF v1.1: ID.SC-1

GV.RM-06: Standardized Risk Management Method

A standardized method for calculating, documenting, categorizing, and prioritizing technology and cybersecurity risks is established and communicated.

Standards:

- Define and document risks through the utilization of risk assessments, threat intelligence, and other threat-sharing resources.
- Evaluate and document known and assumed risks to the organization based on sector risks and potential impactful events.
- Risk acceptance levels are based on risk criteria, established, and documented in accordance with defined resolution time frames and stakeholder approval.
- Review and update risk assessments and risk analyses annually, or when significant enterprise changes occur that could impact this safeguard.
- Stride technology and cybersecurity risk management and risk assessment processes and methodologies are documented and regularly reviewed and updated to address changes in the risk profile and risk appetite, the evolving

threat environment, and new technologies, products, services, and interdependencies.

References:

- CRI Profile v2.0: GV.RM-06
- CRI Profile v2.0: GV.RM-06.01
- SP 800-221A: GV.RR-2
- CSF v1.1: ID.RM-1

GV.RM-07: Strategic Opportunities

Strategic opportunities (i.e., positive risks) are characterized and are included in organizational technology and cybersecurity risk discussions.

Standards:

- Stride has mechanisms in place to ensure that strategies, initiatives, opportunities, and emerging technologies (e.g., artificial intelligence, quantum computing, etc.) are evaluated in terms of risks and uncertainties that are potentially detrimental and potentially advantageous to the organization (i.e., positive risks).

References:

- CRI Profile v2.0: GV.RM-07
- CRI Profile v2.0: GV.RM-07.01